

tation. Often, this requires additional training for the team members. The security team has three areas of responsibilities: policy development, practice, and response. Policy development is focused on establishing and reviewing security policies for the company. At a minimum, review both the risk analysis and the security policy on an annual basis. Practice is the stage during which the security team conducts the risk analysis, the approval of security change requests, reviews security alerts from both vendors and the CERT mailing list, and turns plain language security policy requirements into specific technical implementations.

The last area of responsibility is response. While network monitoring often identifies a security violation, it is the security team members who do the actual troubleshooting and fixing of such a violation. Each security team member should know in detail the security features provided by the equipment in his or her operational area.

While we have defined the responsibilities of the team as a whole, you should define the individual roles and responsibilities of the security team members in your security policy.

Prevention

Prevention can be broken into two parts: approving security changes and monitoring security of your network.

1. Approving Security Changes

Security changes are defined as changes to network equipment that have a possible impact on the overall security of the network. Your security policy should identify specific security configuration requirements in non-technical terms. In other words, instead of defining a requirement as “No outside sources FTP connections will be permitted through the firewall”, define the requirement as “Outside connections should not be able to retrieve files from the inside network”. You’ll need to define a unique set of requirements for your organisation.

The security team should review the list of plain language requirements to identify specific network configuration or design